Insider Risk Readiness Assessment — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Insider Risk Readiness Assessment (Microsoft Purview) 4

The problem . . . 4

The solution . . . 4

What it delivers . . . 4

Business outcomes . . . 5

Boundaries (so scope is clear) . . . 5

1. Solution Overview — Insider Risk Readiness Assessment (Microsoft Purview) 5

What this solution is . . . 5

Why this matters . . . 6

How it works . . . 7

The IRM role-separation model (the core discipline) . . . 7

The least-exposing → scoped journey . . . 8

What you can control . . . 8

Limitations (be honest with buyers) . . . 8

Naming convention (used in every doc and script) . . . 9

The standard deployment model . . . 9

2. Requirements — Insider Risk Readiness Assessment (Microsoft Purview) 10

2.1 Licensing sufficient for Insider Risk Management (verify) . . . 10

2.2 The IRM role groups, assigned as SEPARATED duties . . . 10

2.3 Privacy-by-design settings: anonymization ON and minimum indicators . . . 11

2.4 The connectors the intended policy needs (HR / Entra / DLP / Defender), healthy . . . 11

2.5 Audit logging enabled (the correlation substrate) . . . 12

2.6 The readiness scope: a priority-user group and a chosen template . . . 12

2.7 The HR / privacy / legal stakeholder sign-off path . . . 13

Global Requirements — Microsoft Purview Solutions 14

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 14

2. Purview roles (least-privilege) and portal access . . . 15

3. Security & Compliance PowerShell + Graph toolchain . . . 15

4. Data sources & scope in scope . . . 15

5. Compliance, records, privacy & legal stakeholders . . . 15

6. A pilot scope and change control . . . 16

3. Implementation Guide — Insider Risk Readiness Assessment (Microsoft Purview) 16

Phase 0 — Connect and baseline (Assess) . . . 17

Phase 1 — Establish the privacy-by-design posture (Design → Configure, least-exposing) . . . 17

Phase 2 — Separate the IRM roles (Configure — the central control) . . . 18

Phase 3 — Prepare and health-check the connectors (Configure) . . . 18
Phase 4 — Pilot in the least-exposing mode: Analytics, then a disabled/minimal policy (Pilot) . . . 19
Phase 5 — Validate and hand off (Validate → Expand is HR/privacy/legal's call) . . . 20
Order-of-operations summary . . . 20
5. Testing & Validation — Insider Risk Readiness Assessment (Microsoft Purview) 21
Test A — Licensing & privacy-by-design (the capability is present and private) . . . 21
Test B — Role separation (the central control) . . . 22
Test C — Signal substrate (audit + connectors present and healthy) . . . 23
Test D — Least-exposing scope & pilot (nothing runs against anyone) . . . 23
Pseudonymization & data-handling validation . . . 24
Evidence to capture (for the deliverable record) . . . 25
6. Troubleshooting — Insider Risk Readiness Assessment (Microsoft Purview) 25
Visibility / licensing . . . 25
Roles & separation . . . 26
Privacy / anonymization . . . 26
Connectors & signal . . . 27
Scope & policy . . . 27
Tooling / PowerShell surface . . . 28
7. Best Practices — Insider Risk Readiness Assessment (Microsoft Purview) 29
Privacy-by-design is the deployment — do it first . . . 29
Separate the roles — ruthlessly . . . 29
Start in the least-exposing mode — Analytics before policy . . . 30
Get the connectors right (signal without over-collection) . . . 30
Be honest about what is scriptable . . . 30
Keep the scaffold non-operational until the decision is made . . . 31
Operations & governance (for when it goes live — hand these to the owners) . . . 31
Stay inside the boundary . . . 31
8. Deliverables Summary — Insider Risk Readiness Assessment (Microsoft Purview) 31
Documentation . . . 31
PowerShell tools (5) — Security & Compliance PowerShell / Microsoft Graph . . . 32
Definition of done . . . 33
Appendix A — PowerShell Scripts 35

Executive Summary — Insider Risk Readiness Assessment (Microsoft Purview)

The problem

Insider risk — data walking out with a departing employee, a disgruntled user exfiltrating records, a security-policy violation on a managed device — is real, and **Microsoft Purview Insider Risk Management (IRM)** is built to surface it. But IRM is the most **privacy- and HR-sensitive** capability in Purview: it examines what named people do. Switched on carelessly — every indicator enabled, real usernames visible to everyone, one over-broad policy scoped to the whole tenant on day one — it becomes an employee-surveillance liability, a works-council/privacy problem, and a flood of un-triageable alerts that no one can lawfully act on. The groundwork that makes IRM defensible — privacy posture, role separation, connectors, scope — is exactly what teams skip in the rush to turn it on.

The solution

An **Insider Risk Readiness Assessment**: the disciplined groundwork **before** IRM is deployed against any named user, using only the Microsoft Purview portal, Security & Compliance PowerShell, and Microsoft Graph. It confirms **licensing**; establishes **privacy-by-design** (anonymization **on** so triage is pseudonymized, and only the **minimum** indicators enabled); stands up **strict role separation** — Insider Risk Management **Admins**, **Analysts**, **Investigators**, and **Auditors** as **different people**, kept separate from HR and Legal; prepares and health-checks the **connectors** (HR, Entra, DLP, Defender for Endpoint) that feed the signals; and **scopes** narrowly — proving IRM has signal with a tenant **Analytics** scan (aggregated, **anonymized**, **no policy**) before creating a single **disabled/minimal** readiness policy against a small priority-user group. Everything is done in the **least-exposing mode first**. The result: the capability is licensed, private, role-separated, connected, and scoped — proven ready and defensible — **without ever running against an individual**.

What it delivers

- A configured **privacy-by-design posture** — anonymization on, minimum indicators, documented and signed off

by the privacy stakeholder.

- **Strict role separation** across Admins / Analysts / Investigators / Auditors, with the all-powerful

super-group minimized and HR/Legal kept out of the de-anonymizing Investigator role.

- **Prepared, health-checked connectors** (HR / Entra / DLP / Defender) so the intended template has signal —

and no unnecessary connector over-collecting.

- An **Analytics-first** validation (aggregated, anonymized insight, no named-user policy) and a **disabled/

minimal** readiness policy scoped to a priority-user group you control.

• A **pseudonymized readiness scorecard** — counts and gate status, no personal data — to hand to HR, privacy,

and legal, who own the decision to deploy.

• **Five PowerShell tools** (readiness discovery, scaffold config, validation, pseudonymized report, scope

helper) — read-only or `-WhatIf` by default, no credentials in code, and honest about IRM's limited scriptable surface (they direct you to the portal for the portal-only steps rather than inventing a cmdlet).

Business outcomes

• **IRM deployed responsibly, not recklessly** — privacy and role separation are in place *before* anyone is

monitored, which is what makes the capability defensible to employees, privacy officers, and works councils.

• **Least-exposing by design** — analytics and pseudonymized data before policies; a disabled/minimal pilot

before any expansion; nothing operating against an individual during the assessment.

• **Auditable readiness** — every gate (licensing, privacy, roles, connectors, scope) is validated with

evidence, giving a defensible posture and a clean handoff.

• **Self-guided at a fraction of consulting cost** — the same method a specialist would use, documented and

tooled to run in-house.

Boundaries (so scope is clear)

IRM is licensing-/plan-dependent — it typically requires **E5 / E5 Compliance / an Insider Risk Management add-on** (verify your tenant) — and it is **largely portal-configured** with a limited PowerShell/Graph surface, so the tooling reports what it can and directs you to the portal for the rest. This solution provides the technical **readiness** and the evidence; the decision to **deploy** IRM, the **lawfulness of monitoring** in your jurisdiction, whether to **open a case**, what a risk signal **means** for a person, and any **HR/disciplinary/legal action** are **HR, privacy, and legal determinations**, captured alongside the delivered evidence. The assessment operates against **no** individual.

1. Solution Overview — Insider Risk Readiness Assessment (Microsoft Purview)

What this solution is

Microsoft Purview Insider Risk Management (IRM) correlates signals from across Microsoft 365 — data exfiltration activity, downloads, sharing, DLP matches, device events, and HR context such as a resignation or a role change — to surface *potentially risky user activity* for human review. It is one of the

most powerful capabilities in Purview and also the most **privacy- and HR-sensitive**: it looks at what named people do. Turned on carelessly — every indicator enabled, real usernames visible to everyone, one over-broad policy scoped to the whole tenant on day one — it becomes an employee-surveillance liability, a works-council/privacy problem, and a flood of un-triageable, un-actionable alerts.

This solution is deliberately **not** a full enforced IRM deployment. It is an **Insider Risk Readiness Assessment** — the *groundwork you do before you deploy*: confirming licensing, establishing the **privacy-by-design** posture (pseudonymization/anonymization on, minimal indicators, data-minimizing scope), standing up **strict role separation** (Insider Risk Management **Admins**, **Analysts**, **Investigators**, and **Auditors** as distinct people, kept separate from HR and Legal), preparing the **connectors** (HR, Entra, DLP, Defender for Endpoint) that feed the signals, and **scoping** the first policy and priority-user group — then proving readiness with a tenant **Analytics** scan (aggregated, anonymized insights that require *no* policy) before any named-user policy is created. Everything is done in the **least-exposing mode first**: analytics/insights and pseudonymized data before policies; a disabled or minimal-scope readiness policy before any expansion.

> ***Scope boundary — case and policy OUTCOMES are deferred.*** *This solution delivers the **technical readiness method and the evidence** — is the tenant licensed, is privacy configured, are roles separated, are connectors healthy, is the scope correct. It does **not** make insider-risk determinations. **Whether** to open a case, **what** a risk score means for a specific person, any **HR, disciplinary, or legal action**, and the **applicability** of employment/privacy law (works-council consultation, regional monitoring rules, notice obligations) are **HR, privacy, and legal determinations** — deferred to those functions. Purview surfaces signals for review; people decide. This assessment prepares the capability responsibly; it does not operate it against anyone.*

Why this matters

- **Privacy groundwork is the deployment.** IRM without a privacy posture is a surveillance tool. Purview

ships **pseudonymization** (anonymized usernames) that should be **on before any analyst sees data**, and the deployment should collect the **minimum** indicators needed — getting this right *first* is what makes the capability defensible to employees, privacy officers, and works councils.

- **Role separation is not optional.** The people who *configure* policies (Admins), *triage* alerts

(Analysts), *investigate* case content and forensic evidence (Investigators), and *audit the auditors* (Auditors) must be **different people**, and IRM must be **separate from HR and Legal** — who are stakeholders and reviewers, not holders of the technical investigation role. Collapsing these roles is the classic governance failure.

- **Connectors gate the signals.** The high-value templates (e.g. *data theft by departing users*) do

nothing without the **HR data connector** (resignation dates, role changes) and/or the Entra account-deletion signal; security-violation indicators need **Defender for Endpoint** integration. A policy with no connected signal is inert.

- **Analytics-first is the least-exposing on-ramp.** Purview **Insider Risk Analytics** scans the tenant and

returns **aggregated, anonymized** insight into potential risk — *without configuring a policy and without naming anyone*. Running analytics before creating a named-user policy is how you validate that IRM has

signal to work with, at the lowest possible privacy exposure.

• **IRM is largely portal-configured.** Unlike DLP, IRM exposes a **limited** PowerShell/Graph surface. This

assessment is honest about that: the delivered scripts report the readiness signals they *can* (role-group membership and separation, audit-log state, licensing signal, the backing scope group) and **direct the operator to the Purview portal** for the parts that are portal-only (analytics scan, connector health, policy/priority-user configuration, pseudonymization toggle) — flagged **"verify in the Purview portal / verify your licensing/tenant"** rather than inventing a cmdlet.

How it works

1. **Privacy-by-design settings** define *how much* IRM exposes. In **Purview portal → Insider Risk

Management → Settings → Privacy**,** anonymization ("Show anonymized versions of usernames") **is turned** on **so analysts triage pseudonymized identities; only an authorized** Investigator **can de-anonymize within a case. Indicators are enabled to the** minimum** needed.

1. **Role groups** define *who can do what*. Purview provides distinct IRM role groups — **Insider Risk

Management Admins**,** Analysts**,** Investigators**,** Auditors **(and the all-powerful** Insider Risk Management **super-group, held by almost no one). This assessment assigns them as** separated** duties.

1. **Connectors** define *what signal exists*. The **HR data connector** imports resignation/role-change/

performance events; **Entra** provides account-deletion; **DLP** and **Defender for Endpoint** provide data-movement and security-violation indicators; optional **healthcare** and **physical-badging** connectors add domain signal. Readiness confirms the ones the intended policy needs are present and healthy.

1. **Analytics (insights, no policy)** scans the tenant and returns **aggregated, anonymized** potential-risk

insight — the least-exposing way to confirm IRM has something to detect, run **before** any named policy.

1. **Scoping** defines *who a policy watches*. A **priority user group** (backed by an Entra security group)

and a policy **template** (e.g. *data theft by departing users*) are scoped **narrowly** — created **disabled or minimal** as a readiness pilot, never broadly enforced from the assessment.

1. **Validation** proves each readiness gate (licensing, privacy, roles/separation, connectors, scope) with

pass/fail evidence, and a **pseudonymized scorecard** is produced for stakeholder review — containing no personal data.

The IRM role-separation model (the core discipline)

Role group	Can do	Kept separate from
Insider Risk Management Admins	Create/edit policies, settings, connectors — *configuration only*	Triage, investigation, audit
Insider Risk Management Analysts	Triage alerts and work cases on **pseudonymized** data; **cannot** view forensic/case content in Content Explorer	Configuration, de-anonymized content

Role group	Can do	Kept separate from
Insider Risk Management Investigators	Full case content, forensic evidence, **de-anonymized** identity within a case	Policy configuration, being the sole auditor
Insider Risk Management Auditors	Review the **IRM audit trail** (what admins/analysts/investigators did)	Being anyone they audit
Insider Risk Management (super-group)	**All of the above** — grant to almost no one	Everyone; hold under tight change control

> ***HR and Legal are stakeholders and reviewers — not the technical investigation role.*** *They receive escalations and make the employment/legal determination; they should* ***not*** *by default hold the Investigator role that de-anonymizes and reads case content.*

The least-exposing → scoped journey

> *Confirm licensing → turn* ***anonymization ON*** *and enable* ***minimum*** *indicators (privacy-by-design) → separate the* ***Admin / Analyst / Investigator / Auditor*** *roles (and keep IRM separate from HR/Legal) → prepare and health-check* ***connectors*** *(HR, Entra, DLP, Defender) → run* ***Analytics*** *(aggregated, anonymized insight,* ***no policy****) → scope a* ***priority-user group*** *and a* ***readiness policy*** *narrowly,* ***disabled/minimal*** *→* ***validate*** *every readiness gate → hand the* ***pseudonymized readiness scorecard*** *to HR/privacy/legal, who own the decision to expand and operate.*

What you can control

• The **privacy posture**: anonymization on/off, which **indicators** are enabled, how data-minimizing the scope is.

• **Role separation**: who is an Admin vs Analyst vs Investigator vs Auditor, and that no one holds conflicting roles or the super-group unnecessarily.

• Which **connectors** are prepared (HR, Entra, DLP, Defender for Endpoint, healthcare, physical badging) and whether they are healthy.

• The **priority-user group** membership (readiness scope) and the **policy template** chosen for the readiness pilot.

• Whether IRM is validated with **Analytics only** first, and whether the first policy is **disabled/minimal** before any expansion.

Limitations (be honest with buyers)

• **IRM is licensing-gated** — it typically requires **Microsoft 365 E5**, the **E5 Compliance** add-on, or a dedicated **Insider Risk Management** add-on (some capabilities are in preview). A policy or the analytics scan will not be available without the plan — **verify your licensing/tenant**.

- **IRM is largely portal-configured with a limited PowerShell/Graph surface.** The scripts here report what

is scriptable (role groups & separation, audit-log state, licensing signal, the backing scope group) and **direct you to the Purview portal** for analytics, connector health, pseudonymization, and policy/priority configuration. We do **not** invent cmdlets for the portal-only parts.

- **Signal depends on connectors and audit logging.** No HR connector → no departing-user context; audit

logging off → little to correlate; Defender not integrated → no security-violation indicators.

- **Case and policy outcomes are HR/privacy/legal determinations**, not technical defaults. This assessment

prepares and proves the capability; it does not investigate, score, or act against any individual, and it does not opine on the legality of monitoring in your jurisdiction.

Naming convention (used in every doc and script)

Every artifact this assessment references uses `<Purpose> – <Scope> – <Stage>`, reused verbatim across the docs, scripts, and the Purview portal. The standard set:

Artifact	Name
Priority user group (backing Entra security group)	`IRM Priority Users – Readiness – Scope`
Tenant analytics scan (insights, no policy)	`IRM Analytics – Insights – Tenant`
Readiness policy (created disabled/minimal, analytics-informed)	`IRM – Data Theft Departing Users – Readiness Pilot`
HR data connector	`HR Connector – Readiness`
Role-separation model	`IRM Roles – Admins / Analysts / Investigators / Auditors`
Priority physical assets list (optional)	`IRM Physical Assets – Readiness`
Privacy / anonymization setting	`Anonymization – On – Readiness`
Readiness scorecard (pseudonymized)	`IRM Readiness Scorecard – Stakeholder Review`

The standard deployment model

> ***Assess*** *licensing, current IRM posture, roles, and connectors →* ***Design*** *the privacy posture, role separation, connector set, and initial scope →* ***Configure*** *privacy-by-design (anonymization on, minimum indicators), the backing scope group, and the readiness policy* ***disabled/minimal*** *→* ***Pilot*** *with an* ***Analytics*** *scan (aggregated, anonymized — no named policy) and a minimal-scope readiness policy →* ***Validate*** *every readiness gate with pass/fail evidence →* ***Expand*** *to operational IRM* ***only*** *on the HR/privacy/legal decision. Everything starts in the least-exposing mode, with a documented rollback and the outcome decision deferred to the governance functions.*

2. Requirements — Insider Risk Readiness Assessment (Microsoft Purview)

These are the **solution-specific** prerequisites for an Insider Risk Management (IRM) **readiness assessment** — the privacy, roles/role-separation, connectors, and scoping groundwork you complete **before** deploying IRM against named users. They build on — and do not repeat — the six shared prerequisites in `global-requirements-purview.md` (tenant + compliance licensing, least-privilege Purview roles, S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope + change control). Verify each item below before starting the Implementation Guide.

For every requirement: **Description** (what it is), **Why required**, **How to verify**, **How to implement if missing**.

> ***IRM is largely portal-configured with a limited PowerShell/Graph surface.*** *Several items below are verified in the* ***Microsoft Purview portal****, not by a cmdlet. Where that is the case it is stated and flagged* ***"verify in the Purview portal / verify your licensing/tenant"*** *— this assessment never invents a cmdlet or portal path.*

2.1 Licensing sufficient for Insider Risk Management (verify)

• **Description:** IRM is **plan-gated**. It typically requires **Microsoft 365 E5**, the **Microsoft 365 E5

Compliance **add-on, or a dedicated** Insider Risk Management **add-on (education A5/A5 Compliance equivalents apply; some capabilities and analytics features may be in** preview**). This extends GR-#1 with the IRM-specific plan detail.

• **Why required:** Without the plan, **Insider Risk Management does not appear** in the Purview portal, the

Analytics scan is unavailable, and no policy can be created — the entire capability is inert.

• **How to verify:** In the **Microsoft 365 admin center** confirm the subscription/add-ons; in the

Purview portal confirm **Insider Risk Management** is visible and openable. The Discovery script also reports a licensing **signal** by inspecting subscribed SKU service plans for an insider-risk plan — treat it as a signal, and **flag "verify your licensing/tenant."**

• **How to implement if missing:** Acquire/assign the required licensing before configuring; do not scaffold

policies against a plan you do not hold.

2.2 The IRM role groups, assigned as SEPARATED duties

• **Description:** The distinct Purview **IRM role groups** — **Insider Risk Management Admins**

(configure policies/settings/connectors), **Insider Risk Management Analysts** (triage alerts / work cases on **pseudonymized** data), **Insider Risk Management Investigators** (full case content, forensic evidence, **de-anonymized** identity within a case), and **Insider Risk Management Auditors** (review the IRM audit trail) — plus the all-powerful **Insider Risk Management** super-group. These must be assigned to

different people, and IRM must be kept **separate from HR and Legal**. Extends GR-#2. This is the central control of an IRM deployment.

• **Why required:** Collapsing configuration, triage, investigation, and audit into one person (or handing the

Investigator/de-anonymization role to HR/Legal by default) destroys the separation-of-duties that makes IRM defensible and privacy-respecting. Least privilege here is a privacy control, not just a security one.

• **How to verify: Purview portal** → **Settings** → **Roles & scopes** → **Permissions** (or Microsoft Purview

roles); confirm membership of each IRM role group. The Discovery/Validate scripts enumerate the IRM role groups (`Get-RoleGroup` / `Get-RoleGroupMember`) and **flag separation conflicts** — the same identity in conflicting roles, or membership of the super-group.

• **How to implement if missing:** Assign each least-privilege IRM role group to a **different** named owner

under change control; remove anyone from the super-group who does not require it; ensure HR/Legal are **reviewers/escalation** recipients, not default Investigators.

2.3 Privacy-by-design settings: anonymization ON and minimum indicators

• **Description:** The IRM **privacy** posture — **anonymization ("Show anonymized versions of usernames")

turned ON **so analysts triage** pseudonymized **identities, and only the** minimum indicators **enabled for the intended policy. Configured in** Purview portal → Insider Risk Management → Settings → Privacy **and** → Policy indicators**.

• **Why required:** IRM examines what named people do; **privacy-by-design is the deployment**. Anonymization

is what lets triage happen without exposing identities, and minimizing indicators collects only what the policy needs — both are prerequisites to a defensible, works-council-/privacy-officer-acceptable rollout.

• **How to verify: Purview portal** → **Insider Risk Management** → **Settings** → **Privacy** shows the anonymization

setting; → **Policy indicators** shows enabled indicators. This is a **portal setting** — the scripts **direct you to verify it in the portal** (they do not toggle it) and flag it in the readiness scorecard.

• **How to implement if missing:** Turn anonymization **on** before any analyst has access; enable only the

indicators the intended template requires; document the privacy decision with the privacy stakeholder.

2.4 The connectors the intended policy needs (HR / Entra / DLP / Defender), healthy

• **Description:** The **signal connectors** for the readiness policy: the **HR data connector**

(`HR Connector – Readiness`) for resignation dates, role changes, and performance/PIP events (required by *departing-user* / *disgruntled-user* templates); the built-in **Entra** account-deletion signal;

DLP policy signal; and **Microsoft Defender for Endpoint** integration for security-violation indicators. Optional **healthcare** and **physical-badging** connectors for those domains. Extends GR-#4.

- **Why required:** Templates are inert without their connectors — *data theft by departing users* needs the

HR resignation signal or Entra account deletion; security-violation indicators need Defender integration. Readiness confirms the required connectors exist and are healthy *before* a policy is scoped.

- **How to verify: Purview portal** → **Data Connectors** shows configured connectors and their health/last

import; **Insider Risk Management** → **Settings** shows Defender/DLP integration. Connector health is **portal- verified** — the scripts flag it as a portal check in the scorecard (connector state is not reliably scriptable). **Flag "verify in the Purview portal."**

- **How to implement if missing:** Stand up and schedule the **HR data connector** (CSV/API import per

Microsoft docs), enable the Entra/DLP/Defender signals the template needs, and confirm a successful import before scoping the policy.

2.5 Audit logging enabled (the correlation substrate)

- **Description:** The **unified audit log** must be **enabled** in the tenant — IRM correlates M365 audit

activity (downloads, sharing, DLP matches, device events) into risk signals.

- **Why required:** With audit logging off, IRM has little to correlate and the readiness reporting/validation

scripts (which read audit state) cannot confirm a signal substrate exists.

- **How to verify:** The Discovery/Validate scripts read the audit configuration

(`(Get-AdminAuditLogConfig).UnifiedAuditLogIngestionEnabled`) and report PASS/FAIL; also confirm in the Purview portal audit page.

- **How to implement if missing:** Enable unified audit logging (`Enable-OrganizationCustomization` /

`Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled $true` per Microsoft docs) and allow ingestion to begin before relying on IRM signal.

2.6 The readiness scope: a priority-user group and a chosen template

- **Description:** A **narrow readiness scope** — a **priority user group** (`IRM Priority Users – Readiness –

Scope, backed by an Entra security group) and a chosen **policy template** (e.g. *data theft by departing users* → IRM – Data Theft Departing Users – Readiness Pilot`). The policy is created **disabled or minimal**; priority-user groups define who a policy watches most closely. Extends GR-#6.

- **Why required:** IRM must never be switched on broadly from an assessment. A small, named priority-user

scope (backed by a security group you control) is the least-exposing way to prove the policy is wired correctly before any expansion — and the expansion decision is HR/privacy/legal's, not the assessment's.

- **How to verify:** The backing security group's existence and membership are scriptable (Graph) — the

Config/Set-Scope scripts create/report it; the **priority-user-group binding and the policy** are **portal-configured** and verified in **Insider Risk Management** → **Settings** → **Priority user groups** and → **Policies**. **Flag "verify in the Purview portal."**

- **How to implement if missing:** Create the backing group (Config script, `-Commit`), keep it minimal, bind

it as a priority user group in the portal, and create the template policy **disabled/minimal** — expansion deferred.

2.7 The HR / privacy / legal stakeholder sign-off path

- **Description:** A named path to the **HR, privacy, and legal** stakeholders who own IRM **outcomes** —

works-council/employee-representation consultation where applicable, regional monitoring/notice obligations, the decision to open cases, and any disciplinary/legal action. Extends GR-#5 with IRM's HR sensitivity.

- **Why required:** IRM's outputs are about people. The **determination** — whether monitoring is lawful in a

jurisdiction, whether to act on a signal, what a case means — is **not** technical. The readiness scorecard is handed to these stakeholders; they own expansion and operation.

- **How to verify:** Confirm the named HR/privacy/legal owners, any works-council/consultation requirement,

and the escalation path for alerts. Confirm they are **reviewers/escalation recipients**, not default holders of the Investigator role (Req 2.2).

- **How to implement if missing:** Identify the owners, complete any required consultation, and agree the

escalation/decision path **before** IRM produces anything about a named person.

Requirements summary

#	Requirement	Gate
GR 1–6	Category prerequisites (`global-requirements-purview.md`)	Tenant/licensing, roles, toolchain, scope, stakeholders, pilot + change control
2.1	IRM licensing (E5 / E5 Compliance / IRM add-on; verify)	IRM & Analytics available
2.2	IRM role groups assigned as **separated** duties	Admin/Analyst/Investigator/Auditor distinct; super-group minimal; separate from HR/Legal

#	Requirement	Gate
2.3	Privacy-by-design: **anonymization ON** + minimum indicators	Pseudonymized triage; data-minimizing
2.4	Connectors (HR / Entra / DLP / Defender) present & healthy	The template has signal
2.5	Unified audit logging enabled	Correlation substrate exists
2.6	Readiness scope: priority-user group + template, **disabled/minimal**	Least-exposing pilot only
2.7	HR / privacy / legal sign-off path	Outcomes owned by governance functions

> ***Deferred to HR / privacy / legal:*** *whether monitoring is lawful in your jurisdiction, works-council/ consultation requirements, whether to open a case, what a risk score means for a person, and any disciplinary/legal action. This solution delivers the technical* ***readiness*** *method and evidence, not the determination — and it operates against* ***no*** *individual.*

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The* ***Microsoft Purview portal*** *(purview.microsoft.com), the* ***Microsoft 365 admin center****,* ***Security & Compliance PowerShell*** *(`Connect-IPPSSession`), and* ***Microsoft Graph*** *are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily* ***licensing-/plan-dependent*** *(many require* ***Microsoft 365 E5*** *or the* ***E5 Compliance*** *add-on; some are in preview) and the portal is* ***actively evolving*** *— capability availability and portal paths are* ***cited or flagged "verify your licensing/tenant"****, never asserted or invented.* ***Regulatory, records-retention, and legal determinations*** *(retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are* ***deferred to the organization's compliance, records, privacy, and legal functions*** *— the solutions provide the technical configuration method and evidence, not the determination. Automation is* ***PowerShell*** *(Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires (E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

• **Description:** Access with the least-privilege **Purview / compliance role** the solution names (e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

• **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.

• **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.

• **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

• **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

• **Why required:** Configuration, automation, and the provided scripts run through these.

• **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.

• **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

• **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams, endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

• **Why required:** Purview policies key off the in-scope workloads and the classification scheme.

• **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with stakeholders.

• **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

• **Description:** Engagement with the **compliance, records-management, privacy, security, and legal** stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

• **Why required:** Purview configuration must align to enterprise policy and legal/records requirements, not technical defaults; several capabilities have HR/legal sensitivity.

• **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.

• **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate → Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Insider Risk Readiness Assessment (Microsoft Purview)

This is the exact, ordered procedure to complete an Insider Risk Management (IRM) **readiness assessment** — the privacy, roles/role-separation, connectors, and scoping groundwork done **before** IRM is deployed against named users. Everything is done in the **least-exposing mode first**: privacy settings (anonymization on, minimum indicators) and role separation before any signal is viewed; a tenant **Analytics** scan (aggregated, anonymized — **no policy**) before any named-user policy; a **disabled/minimal** readiness policy before any expansion. Portal paths and cmdlets are from Microsoft's public documentation; **licensing-/plan-dependent features and evolving portal paths are flagged "verify your licensing/tenant"** and never asserted for your tenant. Do the phases in order. Each phase names its artifacts (from the Overview naming table), states a **pass/fail gate**, and gives a **rollback**.

> ***Automation reality.*** *IRM has a **limited PowerShell/Graph surface** — it is largely **portal-configured**. The five delivered tools report what *is* scriptable (role groups & separation, audit-log state, licensing signal, the backing scope group via Microsoft Graph) and **direct you to the Purview portal** for the portal-only steps (Analytics scan, connector health, pseudonymization toggle, policy/priority-user configuration). Scripts are **read-only or** `-WhatIf` **by default**; writes require an explicit* `-Commit`*, and **no script ever enables an IRM policy or enforcement**. No credentials are stored in code.*

> ***Outcomes deferred.*** *Whether monitoring is lawful in your jurisdiction, any works-council/consultation requirement, whether to open a case, what a risk signal means for a person, and any HR/disciplinary/legal action are* ***HR / privacy / legal determinations****. This guide prepares and proves the capability; capture those decisions before Phase 5, and note the assessment operates against* ***no*** *individual.*

Phase 0 — Connect and baseline (Assess)

1. **Connect the toolchain** (GR-#3). On the admin workstation:

```
Install-Module ExchangeOnlineManagement -Scope CurrentUser -Force   # provides Connect-IPPSSession
Connect-IPPSSession -UserPrincipalName admin@contoso.com            # Security & Compliance PowerShell
Connect-MgGraph -Scopes 'Organization.Read.All','Group.Read.All' -NoWelcome   # licensing signal, scope
```

1. **Run the readiness posture assessment** (delivered script #1, read-only):

```
.\IRMASSESS-Discovery.ps1 -CsvPath .\IRMASSESS-Posture.csv
```

It reports the **IRM role groups and their membership + separation conflicts**, the **unified-audit-log** state, a **licensing signal** (subscribed-SKU service plans matching an insider-risk plan), and prints a **portal checklist** for the parts that are portal-only (analytics, connectors, pseudonymization, policies).

1. **Confirm licensing** (Req 2.1) in the M365 admin center / Purview portal — **verify your licensing/tenant**;

do not scaffold against a plan you do not hold.

1. **Confirm the portal-only baseline** in **Purview portal** → **Insider Risk Management**: is IRM openable, is

Analytics available, what (if anything) is already configured under **Settings** and **Policies**?

Pass/fail gate: you have a written baseline — IRM role-group membership (with any separation conflicts flagged), audit-log state, a licensing signal, and a portal note of what already exists. **Rollback:** none (read-only).

Phase 1 — Establish the privacy-by-design posture (Design → Configure, least-exposing)

Do privacy **before** anyone views signal. These are **portal settings** (IRM exposes no cmdlet to toggle them) — the guide directs the exact path; the scripts flag them in the scorecard.

1. **Turn anonymization ON** (`Anonymization – On – Readiness`). **Purview portal → Insider Risk Management →

Settings → Privacy → **select** "Show anonymized versions of usernames." **Analysts will now triage** pseudonymized **identities; only an authorized** Investigator** can de-anonymize within a case.

1. **Enable the MINIMUM indicators** for the intended template. **Settings** → **Policy indicators** → enable only

the indicators the chosen template needs (e.g. for departing-user data theft: the relevant data-exfiltration indicators) — **not** every indicator. Data minimization is a privacy control.

1. **Record the privacy decision** with the privacy stakeholder (Req 2.7): anonymization on, the indicator set,

the retention/region settings, and any works-council/consultation note.

Pass/fail gate: anonymization is **on**, only the minimum required indicators are enabled, and the privacy decision is documented and signed off by the privacy stakeholder — **before** any analyst has access. **Rollback:** privacy settings are non-destructive toggles; revert the indicator set / anonymization in the same portal page. (Anonymization should never be turned *off* without a documented privacy/legal decision.)

Phase 2 — Separate the IRM roles (Configure — the central control)

1. **Confirm/assign the four separated roles. Purview portal** → **Settings** → **Roles & scopes** → **Permissions**

→ assign each IRM role group to a **different** named owner:

- **Insider Risk Management Admins** — configuration only.
- **Insider Risk Management Analysts** — triage on **pseudonymized** data.
- **Insider Risk Management Investigators** — case content / forensic evidence / de-anonymization.
- **Insider Risk Management Auditors** — review the IRM audit trail.

1. **Minimize the super-group.** Remove anyone from the all-powerful **Insider Risk Management** role group who

does not genuinely require full control.

1. **Keep IRM separate from HR/Legal.** Ensure HR and Legal are **escalation/review** recipients, **not**

default holders of the Investigator (de-anonymizing) role (Req 2.2/2.7).

1. **Verify separation with the scripts:**

```
.\IRMASSESS-Discovery.ps1        # lists IRM role groups + members and flags separation conflicts
.\IRMASSESS-Validate.ps1         # per-gate pass/fail incl. role-separation gate
```

A **conflict** = the same identity in two conflicting roles (e.g. Analyst *and* Investigator), or unnecessary super-group membership.

Pass/fail gate: each of Admin / Analyst / Investigator / Auditor is held by a **different** owner; the super-group is minimal; no separation conflict is flagged; HR/Legal are not default Investigators. **Rollback:** role-group membership changes are non-destructive; remove/re-add members (`Remove-RoleGroupMember` / `Add-RoleGroupMember`) to restore separation.

Phase 3 — Prepare and health-check the connectors (Configure)

Templates are inert without their signal. Prepare only the connectors the intended policy needs. Connector setup and health are **portal-configured** — the guide names the steps; the scripts flag connector health as a portal check in the scorecard.

1. **Confirm audit logging is on** (Req 2.5) — the correlation substrate:

```
.\IRMASSESS-Validate.ps1 -Gate Audit   # reads UnifiedAuditLogIngestionEnabled → PASS/FAIL
```

If FAIL, enable unified audit logging per Microsoft docs and allow ingestion before proceeding.

1. **Stand up the HR data connector** (`HR Connector – Readiness`) if the template needs it (departing/

disgruntled-user templates). **Purview portal** → **Data Connectors** → **HR (CSV/API)** → configure the import of resignation dates, role changes, and performance/PIP events → run and confirm a **successful import**.

1. **Enable the built-in signals** the template requires: **Entra account deletion** (departing-user), **DLP**

policy signal, and **Microsoft Defender for Endpoint** integration for security-violation indicators (**Settings** → the relevant integration toggles). Optional **healthcare** / **physical-badging** connectors for those domains.

1. **Verify connector health** in **Purview portal** → **Data Connectors** (last import time / status) — **verify

in the Purview portal**; connector state is not reliably scriptable.

Pass/fail gate: audit logging is on (script PASS); every connector the intended template needs is configured and shows a healthy/recent import in the portal. **Rollback:** a connector can be paused/removed in the portal with no effect on other Purview features; removing an unneeded connector reduces signal collection (a privacy-positive rollback).

Phase 4 — Pilot in the least-exposing mode: Analytics, then a disabled/minimal policy (Pilot)

1. **Run Insider Risk Analytics first** (`IRM Analytics – Insights – Tenant`). **Purview portal → Insider Risk

Management → Analytics → Run scan / Get started. **Analytics returns** aggregated, anonymized **insight into potential risk** without a policy and without naming anyone** — the least-exposing way to confirm IRM has signal to work with. Review the insights with the privacy stakeholder. *(Analytics is portal-only — there is no cmdlet; verify in the portal.)*

1. **Create the backing scope group** (`IRM Priority Users – Readiness – Scope`) — an Entra security group you

control, created **empty** as the readiness scope:

```
.\IRMASSESS-Config.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -WhatIf   # preview
.\IRMASSESS-Config.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -Commit    # create (e
```

The script creates only the **backing group** (empty, least-exposing). Binding it as a **priority user group** and creating the **policy** are portal steps (IRM exposes no policy cmdlet).

1. **Bind the priority user group and create the readiness policy DISABLED/MINIMAL.** **Purview portal →

Insider Risk Management → Settings → Priority user groups → **create the group backed by the security group from step 17. Then** → Policies → Create policy → **choose the template (e.g. *Data theft by departing users*** → `IRM – Data Theft Departing Users – Readiness Pilot`**)** → **scope it to the** priority user group only → **keep it** minimal / do not broadly enable**. *(Template availability and exact wording are version-dependent — verify in your tenant.)*

1. **Adjust the readiness scope narrowly** if needed:

```
.\IRMASSESS-Set-Scope.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -WhatIf      # repo
.\IRMASSESS-Set-Scope.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' `
    -AddMember 'pilotuser@contoso.com' -Commit                                                  # narr
```

Keep the scope minimal — this is a readiness pilot, not a rollout.

Pass/fail gate: the Analytics scan has run and been reviewed (aggregated/anonymized); the backing scope group exists and is minimal; the readiness policy exists **disabled/minimal**, scoped to the priority-user group only. **No broad enforcement. Rollback:** the Analytics scan changes nothing about individuals; the readiness policy can be **deleted or kept disabled** in the portal; the backing group can be emptied/deleted (`IRMASSESS-Set-Scope.ps1 -RemoveMember ... -Commit`) with no residual effect.

Phase 5 — Validate and hand off (Validate → Expand is HR/privacy/legal's call)

1. **Validate every readiness gate:**

```
.\IRMASSESS-Validate.ps1 -CsvPath .\IRMASSESS-Validation.csv
```

Confirms licensing signal, audit-log state, role separation, the backing scope group, and prints the portal-verified gates (privacy/anonymization, connectors, analytics, policy) as **PASS / FAIL / VERIFY-IN-PORTAL**.

1. **Produce the pseudonymized readiness scorecard** for stakeholder review — **no personal data**:

```
.\IRMASSESS-Report.ps1 -CsvPath .\IRMASSESS-Scorecard.csv
```

It emits **counts and gate status only** (role-group member *counts*, not names; gate pass/fail; portal-check reminders) — safe to share with HR/privacy/legal.

1. **Hand the scorecard to HR / privacy / legal** (Req 2.7). **Expansion to operational IRM — enabling the

policy against named users, broadening scope, opening cases — is their decision**, made against employment/ privacy law and any works-council consultation. This assessment stops at *readiness proven*.

1. **Record the evidence** (baseline, validation, scorecard, the privacy sign-off, the role-separation

confirmation) as the deliverable record.

Pass/fail gate: every readiness gate is PASS or an explicit documented VERIFY-IN-PORTAL; the pseudonymized scorecard is produced and handed to HR/privacy/legal with the expansion decision explicitly theirs. **Rollback:** the entire readiness scaffold is non-operational — the policy stays disabled, the scope group can be emptied/deleted, privacy settings persist; nothing has run against an individual, so there is nothing to undo operationally.

Order-of-operations summary

Phase	Do	Artifact(s)	Gate	Rollback
0 Assess	Connect, baseline roles/audit/licensing, portal recon	Posture CSV	Baseline captured	n/a (read-only)
1 Privacy	Anonymization **ON**, minimum indicators	`Anonymization – On – Readiness`	Privacy posture set + signed off	Revert toggles (portal)
2 Roles	Separate Admin/Analyst/Investigator/Auditor; minimize super-group	Role-separation model	4 owners distinct, no conflict	Re-set membership
3 Connectors	Audit on; prepare HR/Entra/DLP/Defender; health-check	`HR Connector – Readiness`	Signal present & healthy	Pause/remove connector
4 Pilot	**Analytics** (no policy) → backing group → **disabled/minimal** policy	Analytics insights, scope group, readiness policy	Analytics reviewed; policy disabled/minimal	Delete/disable policy, empty group
5 Validate	Validate gates; pseudonymized scorecard; hand off	Validation CSV, scorecard	All gates PASS/VERIFY; handed to HR/privacy/legal	Non-operational; nothing to undo

> ***The assessment never operates IRM against an individual.*** *It proves the capability is licensed, private, role-separated, connected, and scoped — then defers the decision to deploy, and every case/outcome, to HR, privacy, and legal.*

5. Testing & Validation — Insider Risk Readiness Assessment (Microsoft Purview)

Validate the IRM **readiness** implementation against explicit **pass/fail gates**. The four headline gates are: **(A) the tenant is licensed and privacy-configured**, **(B) roles are strictly separated**, **(C) the signal substrate (audit + connectors) is present and healthy**, and **(D) the scope is minimal and the pilot is least-exposing**. Because IRM concerns named people, **every test uses fabricated/test data and touches no real individual** — the readiness pilot policy stays **disabled/minimal**, the backing scope group uses **test accounts only**, and the reporting is **pseudonymized (counts, not names)**. Record the evidence.

> *IRM is **portal-configured** for several of these gates — where a test is a portal check it is marked **VERIFY-IN-PORTAL**; the scripts confirm what is scriptable and flag the rest. Nothing here enables a policy or runs IRM against anyone.*

Test A — Licensing & privacy-by-design (the capability is present and private)

#	Test	Steps	Pass condition
A1	Licensing signal	Run `IRMASSESS-Discovery.ps1` and confirm in the M365 admin center.	An insider-risk service plan is present (script signal) **and** IRM is openable in the Purview portal — **verify your licensing/tenant**.
A2	Anonymization ON	**Purview portal → Insider Risk Management → Settings → Privacy.**	**"Show anonymized versions of usernames" is ON** — analysts triage pseudonymized identities. **VERIFY-IN-PORTAL.**
A3	Minimum indicators	**Settings → Policy indicators.**	Only the indicators the intended template needs are enabled — not the full set. **VERIFY-IN-PORTAL.**
A4	Privacy sign-off	Confirm the documented privacy decision (Req 2.7).	Anonymization + indicator set + region/retention are recorded and signed off by the privacy stakeholder.

Gate A (pass): IRM is licensed and openable; anonymization is on; indicators are minimized; the privacy decision is signed off — **before** any analyst has access.

Test B — Role separation (the central control)

#	Test	Steps	Pass condition
B1	Four roles distinct	`IRMASSESS-Discovery.ps1` / `IRMASSESS-Validate.ps1` enumerate the IRM role groups + members.	**Admins, Analysts, Investigators, Auditors** are each held by a **different** owner.
B2	No conflicting membership	Review the scripts' separation-conflict flags.	**No** identity is in two conflicting roles (e.g. Analyst *and* Investigator); the script reports no conflict.

#	Test	Steps	Pass condition
B3	Super-group minimal	Review membership of the **Insider Risk Management** super-group.	The super-group has the minimum necessary members (ideally break-glass only).
B4	Separate from HR/Legal	Confirm who holds **Investigator** (de-anonymization).	HR/Legal are **escalation/reviewers**, **not** default Investigators (Req 2.2/2.7).

Gate B (pass): the four roles are separated across distinct owners, no conflict is flagged, the super-group is minimal, and the de-anonymizing Investigator role is not held by HR/Legal by default.

Test C — Signal substrate (audit + connectors present and healthy)

#	Test	Steps	Pass condition
C1	Audit logging on	`IRMASSESS-Validate.ps1 -Gate Audit` reads `UnifiedAuditLogIngestionEnabled`.	Returns **PASS** (unified audit log enabled) — the correlation substrate exists.
C2	HR connector healthy	**Purview portal** → **Data Connectors** (if the template needs HR).	`HR Connector – Readiness` shows a **recent, successful import**. **VERIFY-IN-PORTAL.**
C3	Built-in signals	**Settings** integration toggles for Entra/DLP/Defender.	The signals the template requires (e.g. Defender for security-violation indicators) are enabled. **VERIFY-IN-PORTAL.**
C4	Connector negative	Confirm no *unneeded* connector is importing data.	Only connectors the intended policy needs are active — data minimization holds.

Gate C (pass): audit logging is on (script PASS) and every connector the intended template requires is healthy in the portal, with no unnecessary connector collecting data.

Test D — Least-exposing scope & pilot (nothing runs against anyone)

#	Test	Steps	Pass condition
D1	Analytics-first	Confirm **Analytics** was run before any policy (**Insider Risk Management** → **Analytics**).	Aggregated, **anonymized** insight was reviewed **without** a named-user policy. **VERIFY-IN-PORTAL.**
D2	Backing group exists & minimal	`IRMASSESS-Set-Scope.ps1 -ScopeGroupName ... -WhatIf` reports members.	`IRM Priority Users – Readiness – Scope` exists and contains **only test accounts** (or is empty).
D3	Policy is disabled/minimal	**Settings** → **Policies.**	`IRM – Data Theft Departing Users – Readiness Pilot` exists **disabled/minimal**, scoped to the priority-user group **only**. **VERIFY-IN-PORTAL.**
D4	No broad enforcement	Confirm no IRM policy is enabled tenant-wide.	No policy is operating against real users — the assessment operates against **no** individual.
D5	Scripts safe-by-default	Run `IRMASSESS-Config.ps1` / `IRMASSESS-Set-Scope.ps1` **without** `-Commit`.	They make **no** change (`-WhatIf` output only); Discovery/Validate/Report are read-only; **no** script enables a policy.

Gate D (pass): Analytics ran before any policy; the scope group is minimal/test-only; the readiness policy is disabled/minimal and narrowly scoped; nothing enforces against real users; scripts are safe-by-default.

Pseudonymization & data-handling validation

#	Test	Pass condition
P1	Scorecard is pseudonymized	`IRMASSESS-Report.ps1` output contains **counts and gate status only** — **no** usernames, no case content, no personal data. Safe to share with HR/privacy/legal.

#	Test	Pass condition
P2	No de-anonymization in readiness	No case is opened and no identity is de-anonymized during the assessment — de-anonymization is an Investigator action inside an operational case, out of scope here.
P3	Evidence access	The readiness evidence (scorecard, validation CSV) is stored where only appropriately-roled stakeholders can read it.

Evidence to capture (for the deliverable record)

• Baseline posture CSV (Phase 0): IRM role-group membership (with separation-conflict flags), audit-log

state, licensing signal.

• The **privacy sign-off** (anonymization on, indicator set, region/retention) — Gate A.

• The **role-separation confirmation** (four distinct owners, super-group minimal, HR/Legal not

Investigators) — Gate B.

• The **connector health** portal screenshots and the audit-log PASS — Gate C.

• The **Analytics-reviewed** note, the minimal backing group membership, and the **disabled/minimal** policy

confirmation — Gate D.

• The **pseudonymized readiness scorecard** (`IRMASSESS-Report.ps1`) handed to HR/privacy/legal — P1.

> ***Determination boundary.*** *These tests prove the capability is **ready** — licensed, private, role-separated, connected, minimally scoped. Whether to **deploy** IRM, whether monitoring is **lawful** in your jurisdiction, whether to **open a case**, and any **HR/disciplinary/legal action** are HR/privacy/legal determinations, captured alongside the evidence above. The assessment runs against **no** individual.*

6. Troubleshooting — Insider Risk Readiness Assessment (Microsoft Purview)

Symptom-first fixes for the failures you actually hit preparing IRM for deployment. Most problems are one of: IRM not visible at all, a role-separation conflict, the Analytics scan or a policy showing nothing, a connector not importing, audit logging off, or "why can't PowerShell do this?" — the answer to which is often **because IRM is portal-configured**. Nothing here operates IRM against an individual.

Visibility / licensing

Insider Risk Management is not visible in the Purview portal (or Analytics is greyed out).

• **Licensing.** IRM requires the appropriate plan (**E5 / E5 Compliance / an Insider Risk Management

add-on**; A5 for education). Check the licensing signal with** `IRMASSESS-Discovery.ps1` **/** `IRMASSESS-Validate.ps1 -Gate Licensing` **and** verify in the M365 admin center**. Without the plan, IRM and the Analytics scan do not appear —** verify your licensing/tenant**.

• **Role.** Even licensed, you need an IRM role to *see* the workload — confirm you hold **Insider Risk

Management Admins** (or the super-group) to configure. A missing role hides the node.

The licensing script signal says "none matched" but I believe we are licensed.

• The signal inspects subscribed-SKU **service plan names** for an insider-risk plan; plan names vary and

evolve. Treat a non-match as *inconclusive*, not *unlicensed* — **verify in the admin center**. The script intentionally flags this as a signal, never an assertion.

Roles & separation

`IRMASSESS-Discovery.ps1` **/** `IRMASSESS-Validate.ps1` **flags a separation conflict.**

• The same identity holds **conflicting** IRM roles (e.g. Analyst *and* Investigator) — separation of duties

is broken. Remove the identity from one role in **Purview portal** → **Settings** → **Roles & scopes** → **Permissions** (or `Remove-RoleGroupMember`) so **Admins / Analysts / Investigators / Auditors** are held by **different** people.

• If the flag is the **super-group** (`Insider Risk Management`): that role grants everything. Reduce it to

break-glass only.

• If HR/Legal appear as **Investigators**: by default they should be **escalation/reviewers**, not holders of

the de-anonymizing Investigator role. Re-assign (Req 2.2/2.7).

A role group isn't found by the script (`VERIFY-IN-PORTAL`**).**

• IRM role-group names can vary by tenant/version. Confirm the actual role groups in **Settings → Roles &

scopes → Permissions** and reconcile — do not assume a name; the script reports what `Get-RoleGroup` returns.

`Get-RoleGroup` **returns nothing / "cmdlet not recognized".**

• You are not connected to **Security & Compliance PowerShell**. Run `Connect-IPPSSession` with a modern-auth/

MFA-capable admin holding a compliance role. `Get-RoleGroup` is an IPPSSession/Exchange cmdlet, not Graph.

Privacy / anonymization

Analysts can see real usernames when triaging.

• **Anonymization is off.** Turn on **"Show anonymized versions of usernames"** in **Insider Risk Management →

Settings → Privacy ***before* granting analyst access. This is a** portal setting** — there is no cmdlet; the scripts flag it as VERIFY-IN-PORTAL, they do not toggle it.

• De-anonymization is an **Investigator** action **inside an authorized case** — that is by design, not a

privacy leak, and it is out of scope for a readiness assessment (no case is opened here).

Too many indicators are enabled.

• Data minimization: enable only what the intended template needs in **Settings** → **Policy indicators**. Excess

indicators mean excess collection and more false signal — trim them.

Connectors & signal

The Analytics scan (or a template) shows little/no potential risk.

• **Audit logging off?** Check `IRMASSESS-Validate.ps1 -Gate Audit`. With the unified audit log disabled, IRM

has almost nothing to correlate — enable it and allow ingestion time.

• **Connector missing.** *Data theft by departing users* needs the **HR connector** (resignation/role-change

signal) or the Entra account-deletion signal; security-violation indicators need **Defender for Endpoint** integration. Confirm the required connector exists and imported recently in **Data Connectors** — **verify in the portal**.

• **Dwell time.** IRM signals accrue over time; a tenant with fresh connectors/audit may simply have little

history yet.

The HR connector isn't importing.

• Connector health is **portal-verified** (**Data Connectors** → the connector's last-import status). Check

the CSV/API source, the schedule, and the field mapping per Microsoft docs. A silently stopped import degrades the departing-user signal without an obvious error — check it on a cadence.

Scope & policy

`IRMASSESS-Config.ps1` **created the backing group, but I don't see a priority user group / policy.**

• **Correct — the script only creates the backing security group.** Binding it as a **priority user group**

and creating the **policy** are **portal steps** (IRM exposes no policy cmdlet): **Settings** → **Priority user groups**, then **Policies** → **Create policy**, scoped to that group, **disabled/minimal**. The script does not (and should not) do this.

The readiness scope group has real users in it.

• Keep the readiness scope **test-accounts-only** until HR/privacy/legal approve deployment. Remove real users

with `IRMASSESS-Set-Scope.ps1 -RemoveMember <upn> -Commit`.

I want the script to enable the policy / turn IRM on.

- **By design, no delivered script enables an IRM policy or enforcement.** Enablement is a deliberate portal/

change-control action and an HR/privacy/legal **decision** — not something the assessment automates. The assessment proves *readiness*; it does not deploy.

Tooling / PowerShell surface

"Why can't PowerShell configure the analytics scan / connector / pseudonymization / policy?"

- **Because IRM is largely portal-configured** — it exposes a limited PowerShell/Graph surface. This is a

Microsoft platform reality, not a gap in the tooling. The scripts reliably handle **role groups, audit state, licensing signal, and the backing scope group (Graph)**, and **direct you to the portal** for the rest. We deliberately do **not** invent a cmdlet for a portal-only step.

A Graph script fails with an authorization/scope error.

- `IRMASSESS-Config.ps1` / `IRMASSESS-Set-Scope.ps1` need Graph scopes — reconnect with

`Connect-MgGraph -Scopes Group.ReadWrite.All,User.Read.All`. Read-only checks need `Group.Read.All` / `Organization.Read.All`. Consent to the scopes with an admin.

A script made an unexpected change.

- The delivered scripts are **read-only or `-WhatIf` by default**; writes require `-Commit`, and the only

writes are **creating an empty backing group** or **adding/removing one scope member**. No script enables a policy. If a change landed, it was committed intentionally — remove the member / delete the empty group to revert; there is no operational IRM state to unwind.

Fast triage table

Symptom	First check
IRM not visible / Analytics greyed out	Licensing (E5/E5 Compliance/IRM add-on) + your IRM role — verify tenant
Separation conflict flagged	Same identity in conflicting roles / super-group / HR-Legal as Investigator — re-assign
Role group "not found" by script	Confirm actual role-group names in Settings > Roles & scopes
`Get-RoleGroup` not recognized	Not connected to S&C PowerShell — `Connect-IPPSSession`
Analysts see real usernames	Anonymization OFF — turn on in Settings > Privacy (portal)
Analytics/policy shows nothing	Audit logging off, connector missing, or dwell time — verify in portal

Symptom	First check
HR connector not importing	Data Connectors last-import status, source/schedule/mapping (portal)
No priority group/policy after Config	Expected — binding + policy are portal steps; Config makes only the backing group
Real users in readiness scope	Keep test-only — `IRMASSESS-Set-Scope.ps1 -RemoveMember -Commit`
"Script won't enable IRM"	By design — enablement is a portal/change-control + HR/privacy/legal decision
Graph script authorization error	Reconnect `Connect-MgGraph` with the needed scopes

7. Best Practices — Insider Risk Readiness Assessment (Microsoft Purview)

Field-tested practices for getting IRM **ready** responsibly — privacy first, roles strictly separated, signal prepared, scope minimal — so that when the organization does deploy, the capability is defensible to employees, privacy officers, works councils, and auditors. These complement the Implementation and Testing guides. The governing principle: **prepare the capability; defer every outcome to HR, privacy, and legal.**

Privacy-by-design is the deployment — do it first

- **Turn anonymization ON before anyone sees signal.** Analysts should triage **pseudonymized** identities by

default; de-anonymization is an **Investigator** action inside an authorized case, not a triage default. Configure it before granting any access.

- **Collect the minimum.** Enable only the **indicators** the intended template needs — not the full catalog.

Data minimization is a privacy control, and fewer indicators mean fewer false signals and a smaller footprint to defend.

- **Consult before you monitor.** Where employment/privacy law or a works council requires **consultation or

notice** before monitoring, that happens *first* — it is a legal prerequisite, not a formality. This assessment prepares the technical capability; the lawfulness of monitoring is legal's determination.

Separate the roles — ruthlessly

- **Four different people: Admins** (configure), **Analysts** (triage on pseudonymized data),

Investigators (case content, forensic evidence, de-anonymization), **Auditors** (audit the others). Collapsing them is the classic governance failure.

• **Almost no one holds the super-group.** The all-powerful **Insider Risk Management** role group should be

break-glass only.

• **HR and Legal are reviewers, not Investigators.** They receive escalations and make the employment/legal

call; giving them the de-anonymizing Investigator role by default breaks separation and privacy. Keep IRM operations separate from the functions that act on its outputs.

• **Audit the auditors.** The Auditor role exists so IRM activity itself is reviewable — use it.

Start in the least-exposing mode — Analytics before policy

• **Run Insider Risk Analytics first.** It returns **aggregated, anonymized** insight into potential risk

without a policy and without naming anyone — the lowest-exposure way to confirm IRM has signal worth acting on. Only after reviewing analytics do you scope a named-user policy.

• **First policy is disabled or minimal, and narrowly scoped** to a **priority-user group** you control —

never tenant-wide from an assessment. Prove the wiring, then let HR/privacy/legal own expansion.

• **Prefer aggregated evidence** for stakeholder conversations. The readiness scorecard is **counts and gate

status**, not names — most decisions can be made without exposing an identity.

Get the connectors right (signal without over-collection)

• **Match connectors to the template.** *Data theft by departing users* needs the **HR connector** (or the

Entra account-deletion signal); security-violation indicators need **Defender for Endpoint** integration. A policy with no connected signal is inert — and a connector with no policy behind it is needless collection.

• **Confirm audit logging is on** — it is the correlation substrate; IRM has little to work with without it.

• **Health-check imports.** An HR connector that silently stopped importing degrades the departing-user signal

without warning — check last-import status on a cadence.

Be honest about what is scriptable

• **IRM is largely portal-configured.** Use the delivered scripts for what they reliably report — **role

groups & separation, audit-log state, licensing signal, the backing scope group **— and use the** Purview portal **for analytics, connector health, pseudonymization, and policy/priority configuration.** Do not trust an invented cmdlet** for a portal-only step.

• **Verify licensing/tenant** before relying on any IRM capability or template — plans and portal paths

evolve and some features are in preview; don't assume a template or the analytics scan exists in your tenant.

Keep the scaffold non-operational until the decision is made

• **Nothing runs against an individual during readiness.** The policy stays disabled/minimal, the scope group

holds test accounts, reporting is pseudonymized. Readiness is proving the capability, not using it.

• **Rollback is trivial because nothing is operating.** Delete/disable the readiness policy, empty the scope

group, revert indicators — there is no operational state to unwind. Preserve this property until HR/privacy/legal decide to deploy.

Operations & governance (for when it goes live — hand these to the owners)

• Give IRM **alerts an owner and an SLA**, and keep **evidence access least-privilege** — case content can

contain highly sensitive personal data.

• Keep a **change log** of every privacy-setting, role, connector, and scope change, with the privacy/legal

sign-off attached.

• **Review role membership and connector health on a cadence** — separation and signal drift over time.

• Re-run **Analytics** periodically as an aggregated health check before expanding scope.

Stay inside the boundary

• IRM **surfaces signals for human review** — it does not decide anything about a person. **Whether monitoring

is lawful, whether to open a case, what a score means, and any disciplinary/legal action are HR/privacy/legal determinations.** You deliver the technical readiness and the evidence; they own the decision and the operation.

8. Deliverables Summary — Insider Risk Readiness Assessment (Microsoft Purview)

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The IRM readiness model — privacy-by-design (anonymization on, minimum indicators), the four-way role-separation model (Admins / Analysts / Investigators / Auditors, separate from HR/Legal), connectors (HR/Entra/DLP/Defender), Analytics-first, and the least-exposing → scoped journey; naming convention.

Document	What it gives you
Requirements Guide	Solution-specific prerequisites (IRM licensing; separated role groups; privacy/anonymization + minimum indicators; HR/Entra/DLP/Defender connectors; unified audit logging; a minimal readiness scope; HR/privacy/legal sign-off) each with verify/implement steps, on top of the six category prerequisites.
Implementation Guide	The exact ordered phases: connect/baseline → privacy-by-design → separate roles → prepare connectors → pilot **Analytics-first then a disabled/minimal policy** → validate & hand off; each phase named, gated, and with a rollback.
Testing & Validation	Pass/fail gates for the four headline outcomes — licensed & private (A), roles separated (B), signal substrate healthy (C), scope minimal & pilot least-exposing (D) — plus pseudonymization/data-handling checks, all with fabricated test data and touching no individual.
Troubleshooting Guide	The common failure modes (IRM not visible, role-separation conflicts, analytics/policy shows nothing, connector not importing, audit off, "why can't PowerShell do X") and how to resolve them.
Best Practices	Privacy-first discipline, ruthless role separation, Analytics-before-policy, connector-to-template matching, honesty about what is scriptable, and keeping the scaffold non-operational until the deploy decision.
Executive Summary	One-page business framing for approvers.

PowerShell tools (5) — Security & Compliance PowerShell / Microsoft Graph

All tools are **read-only or `-WhatIf` by default**; writes require an explicit `-Commit`, and **no tool ever enables an IRM policy or enforcement**. No credentials are stored in code. They connect via `Connect-IPPSSession` (role groups, audit) and/or `Connect-MgGraph` (licensing signal, the backing scope group). Because **IRM is largely portal-configured**, each tool clearly directs the operator to the Purview portal for the portal-only steps it cannot script — it never invents a cmdlet.

#	Script	Role	Default safety
1	**IRMASSESS-Discovery.ps1**	IRM readiness posture: IRM role groups + membership with **separation-conflict** flags, unified-audit-log state, a licensing **signal** (subscribed-SKU service plans), and a portal checklist for analytics/connectors/pseudonymization/policies.	Read-only

#	Script	Role	Default safety
2	**IRMASSESS-Config.ps1**	Readiness-scaffold helper: creates the **backing Entra security group** for the priority-user scope (`IRM Priority Users – Readiness – Scope`) **empty / least-exposing**. Never binds a policy, never enables IRM — those are portal steps.	`-WhatIf` (writes need `-Commit`)
3	**IRMASSESS-Validate.ps1**	Readiness validator: per-gate **PASS / FAIL / VERIFY-IN-PORTAL** for licensing signal, audit-log state, role separation, and the backing scope group; prints the portal-verified gates (privacy/anonymization, connectors, analytics, policy).	Read-only
4	**IRMASSESS-Report.ps1**	**Pseudonymized** readiness scorecard for stakeholder review: **counts and gate status only** (role-group member *counts*, not names) — no personal data, safe to hand to HR/privacy/legal.	Read-only
5	**IRMASSESS-Set-Scope.ps1**	Scope/health helper: reports the backing scope group's membership and (with `-Commit`) **adjusts** it (add/remove a member of the readiness scope). Does not enable any policy.	`-WhatIf` (writes need `-Commit`)

Definition of done

• IRM is **licensed** and openable in the portal (Req 2.1 — verify your licensing/tenant).

• **Privacy-by-design** set: anonymization **ON**, minimum indicators enabled, privacy decision signed off (Gate A).

• **Role separation** proven: Admins / Analysts / Investigators / Auditors held by **different** owners, the super-group minimal, HR/Legal not default Investigators, no separation conflict flagged (Gate B).

• **Signal substrate** ready: unified audit logging on; the connectors the intended template needs (HR/Entra/ DLP/Defender) configured and healthy in the portal (Gate C).

• **Least-exposing pilot** done: **Analytics** run and reviewed (aggregated/anonymized, no policy); the backing scope group minimal/test-only; the readiness policy created **disabled/minimal**, scoped to the priority-user group only; nothing enforcing against real users (Gate D).

• **Pseudonymized readiness scorecard** produced and handed to HR/privacy/legal; scaffold verified non-operational; scripts safe-by-default; change log and privacy sign-off captured.

> ***Boundary:*** *the solution delivers the technical* ***readiness*** *method and the evidence. The decision to* ***deploy*** *IRM, the* ***lawfulness of monitoring*** *in your jurisdiction, whether to* ***open a case****, what a risk*

*signal **means** for a person, and any **HR/disciplinary/legal action** are HR/privacy/legal determinations, captured alongside the evidence. The assessment operates against **no** individual.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

IRMASSESS-Config.ps1

Purpose: Creates the LEAST-EXPOSING readiness scaffold that IS scriptable: the backing Microsoft Entra security group (default name 'IRM Priority Users - Readiness - Scope') that a Purview Insider Risk Management PRIORITY USER GROUP will be bound to in the portal. The group is created EMPTY (no members) so the scaffold exposes no one. Safe by default: with -WhatIf it only reports the intended change; it creates nothing unless -Commit is passed. This helper does NOT create an IRM policy, does NOT bind the priority-user group, and NEVER enables IRM or any enforcement — IRM policy/priority configuration is portal-only (verify in the Purview portal). Members are added deliberately and minimally with IRMASSESS-Set-Scope.ps1. HOW TO RUN Preview creating the empty backing scope group: powershell -File .\IRMASSESS-Config.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -WhatIf Actually create it (empty): powershell -File .\IRMASSESS-Config.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -Commit Requires Microsoft Graph (Connect-MgGraph -Scopes Group.ReadWrite.All). .EXAMPLE .\IRMASSESS-Config.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -WhatIf Prints the New-MgGroup call it WOULD run to create the empty backing security group. .NOTES Purview — Insider Risk Readiness Assessment. Writes gated behind -Commit; creates an EMPTY group only. Never creates/enables an IRM policy. No credentials in code. No individual data. Expected results: -Commit creates the empty backing group; bind it as a priority user group in the portal (PASS). > [CmdletBinding()] param([string]$ScopeGroupName = 'IRM Priority Users - Readiness - Scope', [string]$MailNickname = 'irm-priority-users-readiness-scope', [switch]$Commit)

How to run: Preview creating the empty backing scope group: powershell -File .\IRMASSESS-Config.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -WhatIf Actually create it (empty): powershell -File .\IRMASSESS-Config.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -Commit Requires Microsoft Graph (Connect-MgGraph -Scopes Group.ReadWrite.All). .EXAMPLE .\IRMASSESS-Config.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -WhatIf Prints the New-MgGroup call it WOULD run to create the empty backing security group. .NOTES Purview — Insider Risk Readiness Assessment. Writes gated behind -Commit; creates an EMPTY group only. Never creates/enables an IRM policy. No credentials in code. No individual data. Expected results: -Commit creates the empty backing group; bind it as a priority user group in the portal (PASS). > [CmdletBinding()] param([string]$ScopeGroupName = 'IRM Priority Users - Readiness - Scope', [string]$MailNickname = 'irm-priority-users-readiness-scope', [switch]$Commit)

IRMASSESS-Discovery.ps1

Purpose: Builds the IRM readiness baseline from the signals that ARE scriptable: the Insider Risk Management role groups and their membership (flagging role-SEPARATION conflicts and super-group over-membership), the unified-audit-log ingestion state (the correlation substrate), and a LICENSING signal derived from subscribed-SKU service plans (Microsoft Graph). Insider Risk Management is largely PORTAL-CONFIGURED with a limited PowerShell/Graph surface, so this script also prints a PORTAL CHECKLIST for the parts it cannot script (Analytics scan, connector health, pseudonymization/ anonymization toggle, and policy/priority-user configuration) — flagged "verify in the Purview portal / verify your licensing/tenant". Read-only — makes no changes and touches no individual. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\IRMASSESS-Discovery.ps1 -CsvPath

.\IRMASSESS-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement) for role groups + audit config; optional Microsoft Graph (Connect-MgGraph) for the licensing signal. .EXAMPLE .\IRMASSESS-Discovery.ps1 -CsvPath .\IRMASSESS-Posture.csv Prints the IRM role groups (member counts + separation conflicts), audit-log state, licensing signal, and a portal checklist; exports the role-group inventory CSV. .NOTES Purview — Insider Risk Readiness Assessment. Read-only. No changes, no de-anonymization, no individual data. Expected results: PASS = four IRM roles separated across distinct owners, audit log enabled, licensing signal present. Anything else is flagged for review or for portal verification. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\IRMASSESS-Discovery.ps1 -CsvPath .\IRMASSESS-Posture.csv Requires Security & Compliance PowerShell (Connect-IPPSSession via ExchangeOnlineManagement) for role groups + audit config; optional Microsoft Graph (Connect-MgGraph) for the licensing signal. .EXAMPLE .\IRMASSESS-Discovery.ps1 -CsvPath .\IRMASSESS-Posture.csv Prints the IRM role groups (member counts + separation conflicts), audit-log state, licensing signal, and a portal checklist; exports the role-group inventory CSV. .NOTES Purview — Insider Risk Readiness Assessment. Read-only. No changes, no de-anonymization, no individual data. Expected results: PASS = four IRM roles separated across distinct owners, audit log enabled, licensing signal present. Anything else is flagged for review or for portal verification. > [CmdletBinding()] param([string]$CsvPath, [string]$UserPrincipalName)

IRMASSESS-Report.ps1

Purpose: Produces a readiness SCORECARD for HR / privacy / legal review that contains NO personal data — COUNTS and gate STATUS only. It reports the IRM role groups by member COUNT (never names), the role-SEPARATION result, the unified-audit-log state, a licensing signal, the backing scope group's member COUNT, and the portal-only gates as VERIFY-IN-PORTAL reminders. Deliberately pseudonymized so the output is safe to circulate: no usernames, no case content, no de-anonymized identities. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\IRMASSESS-Report.ps1 -CsvPath .\IRMASSESS-Scorecard.csv Requires Security & Compliance PowerShell (Connect-IPPSSession); optional Microsoft Graph for the licensing signal and the backing-group count. .EXAMPLE .\IRMASSESS-Report.ps1 -CsvPath .\IRMASSESS-Scorecard.csv Prints and exports a counts-and-status readiness scorecard (no personal data) for stakeholder sign-off. .NOTES Purview — Insider Risk Readiness Assessment. Read-only. Output is pseudonymized (counts + status only). Expected results: a scorecard safe to hand to HR/privacy/legal; the deploy/operate decision is theirs. > [CmdletBinding()] param([string]$ScopeGroupName = 'IRM Priority Users - Readiness - Scope', [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\IRMASSESS-Report.ps1 -CsvPath .\IRMASSESS-Scorecard.csv Requires Security & Compliance PowerShell (Connect-IPPSSession); optional Microsoft Graph for the licensing signal and the backing-group count. .EXAMPLE .\IRMASSESS-Report.ps1 -CsvPath .\IRMASSESS-Scorecard.csv Prints and exports a counts-and-status readiness scorecard (no personal data) for stakeholder sign-off. .NOTES Purview — Insider Risk Readiness Assessment. Read-only. Output is pseudonymized (counts + status only). Expected results: a scorecard safe to hand to HR/privacy/legal; the deploy/operate decision is theirs. > [CmdletBinding()] param([string]$ScopeGroupName = 'IRM Priority Users - Readiness - Scope', [string]$CsvPath, [string]$UserPrincipalName)

IRMASSESS-Set-Scope.ps1

Purpose: Reports the membership of the backing Entra security group that a Purview Insider Risk Management PRIORITY USER GROUP is bound to (the readiness scope), and — only with -Commit — ADD or REMOVE a single member so the readiness scope stays minimal. Safe by default: -WhatIf reports only; writes require -Commit. This helper adjusts SCOPE MEMBERSHIP only — it does NOT bind the priority-user group, does NOT create/enable an IRM policy, and never enables enforcement (those are portal-only steps; verify in the Purview portal). Keep the readiness scope test-accounts-only until HR/privacy/legal approve deployment. HOW TO RUN Report current readiness-scope membership: powershell -File .\IRMASSESS-Set-Scope.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -WhatIf Add a test account to the readiness scope: powershell -File .\IRMASSESS-Set-Scope.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' ` -AddMember 'pilotuser@contoso.com' -Commit Requires Microsoft Graph (Connect-MgGraph -Scopes Group.ReadWrite.All,User.Read.All). .EXAMPLE .\IRMASSESS-Set-Scope.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -WhatIf Prints the backing group's member count/list and the membership change it WOULD make. .NOTES Purview — Insider Risk Readiness Assessment. Membership changes gated behind -Commit; never enables a policy. No credentials in code. Expected results: -Commit adjusts scope membership only; no IRM policy is touched (PASS). > [CmdletBinding()] param([string]$ScopeGroupName = 'IRM Priority Users - Readiness - Scope', [string]$AddMember, [string]$RemoveMember, [switch]$Commit)

How to run: Report current readiness-scope membership: powershell -File .\IRMASSESS-Set-Scope.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -WhatIf Add a test account to the readiness scope: powershell -File .\IRMASSESS-Set-Scope.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' ` -AddMember 'pilotuser@contoso.com' -Commit Requires Microsoft Graph (Connect-MgGraph -Scopes Group.ReadWrite.All,User.Read.All). .EXAMPLE .\IRMASSESS-Set-Scope.ps1 -ScopeGroupName 'IRM Priority Users - Readiness - Scope' -WhatIf Prints the backing group's member count/list and the membership change it WOULD make. .NOTES Purview — Insider Risk Readiness Assessment. Membership changes gated behind -Commit; never enables a policy. No credentials in code. Expected results: -Commit adjusts scope membership only; no IRM policy is touched (PASS). > [CmdletBinding()] param([string]$ScopeGroupName = 'IRM Priority Users - Readiness - Scope', [string]$AddMember, [string]$RemoveMember, [switch]$Commit)

IRMASSESS-Validate.ps1

Purpose: Confirms the IRM readiness prerequisites that ARE scriptable and reports a per-gate result: the LICENSING signal (subscribed-SKU service plans via Microsoft Graph), the unified-AUDIT-LOG state, and ROLE SEPARATION (the four IRM role groups held by distinct owners, super-group minimal, no conflicting membership), plus the backing SCOPE group's presence. Gates that IRM only exposes in the portal (privacy/anonymization, connector health, analytics, policy scope) are printed as VERIFY-IN-PORTAL — this script never invents a cmdlet for them. Read-only — makes no changes and touches no individual. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\IRMASSESS-Validate.ps1 -CsvPath .\IRMASSESS-Validation.csv Use -Gate to run a single gate (Licensing | Audit | Roles | Scope | All). Requires Security & Compliance PowerShell (Connect-IPPSSession); optional Microsoft Graph for licensing/scope-group gates. .EXAMPLE .\IRMASSESS-Validate.ps1 -Gate Audit Reads UnifiedAuditLogIngestionEnabled and reports the audit gate PASS/FAIL only. .NOTES Purview — Insider Risk Readiness Assessment. Read-only validator. No changes, no de-anonymization. Expected results: every scriptable gate PASS; portal-only gates printed as VERIFY-IN-PORTAL for sign-off. > [CmdletBinding()] param([ValidateSet('All','Licensing','Audit','Roles','Scope')][string]$Gate = 'All', [string]$ScopeGroupName = 'IRM Priority Users - Readiness - Scope', [string]$CsvPath, [string]$UserPrincipalName)

How to run: powershell -ExecutionPolicy Bypass -File .\IRMASSESS-Validate.ps1 -CsvPath .\IRMASSESS-Validation.csv Use -Gate to run a single gate (Licensing | Audit | Roles | Scope | All). Requires Security & Compliance PowerShell (Connect-IPPSSession); optional Microsoft Graph for licensing/scope-group gates. .EXAMPLE .\IRMASSESS-Validate.ps1 -Gate Audit Reads UnifiedAuditLogIngestionEnabled and reports the audit gate PASS/FAIL only. .NOTES Purview — Insider Risk Readiness Assessment. Read-only validator. No changes, no de-anonymization. Expected results: every scriptable gate PASS; portal-only gates printed as VERIFY-IN-PORTAL for sign-off. > [CmdletBinding()] param([ValidateSet('All','Licensing','Audit','Roles','Scope')][string]$Gate = 'All', [string]$ScopeGroupName = 'IRM Priority Users - Readiness - Scope', [string]$CsvPath, [string]$UserPrincipalName)